

ETHICAL HACKING INTERNSHIP

BATCH 02

WEEK 1 PRE-EXPLOITATION REPORT

Passive & Active Reconnaissance



Target Machine	Metasploitable 2
Target IP	192.168.174.129
Attacker IP	192.168.174.128 (Kali Linux)
Network Range	192.168.174.0/24

Prepared by: Areeba Shafqat
Instructor: Mr. Muhammad Saad
Internship Track: Ethical Hacking
Assessment Scope: Week 1

Contents

1. Executive Summary.....	3
2. Lab Environment & Target Selection.....	3
2.1 Target Machine Selected.....	3
2.2 Environment Configuration	3
Attacker Machine (Kali Linux).....	3
Target Machine (Metasploitable 2).....	4
2.3 Connectivity Verification.....	5
3. Passive Reconnaissance	5
3.1 WHOIS Enumeration	6
3.2 DNS Enumeration	7
3.3 Web Footprinting.....	8
Robots.txt Analysis	9
3.4 Web Technology Fingerprinting	10
4. Active Reconnaissance.....	11
4.1 Host Discovery — ICMP Ping	11
4.2 ARP Discovery (Local Network).....	11
4.3 Port Scanning.....	12
TCP Connect Scan	13
4.4 Service Banner Collection	14
4.5 Service & Version Enumeration	15
4.6 Operating System Detection	17
5. Vulnerability Discovery	18
5.2 Additional Weaknesses.....	18
5.3 Nmap Vulnerability Scan Output.....	19
6. Findings Summary & Risk Matrix.....	22
7. Conclusion	23
8. Tools & References	23

1. Executive Summary

This report documents the Week 1 activities of the Ethical Hacking Internship, Batch 02, focused entirely on the pre-exploitation phase specifically passive and active reconnaissance against a deliberately vulnerable target machine (Metasploitable 2). All activities were performed in an isolated, controlled lab environment with explicit authorization. No production systems or real-world networks were targeted.

The reconnaissance phase revealed a significantly exposed attack surface including **23 open ports, 23 services, and 9 critical vulnerabilities** on the target system.

2. Lab Environment & Target Selection

2.1 Target Machine Selected

Target: Metasploitable 2 a deliberately insecure Ubuntu-based VM designed for penetration testing practice in a safe, legal environment.

2.2 Environment Configuration

Attacker Machine (Kali Linux)

OS	Kali Linux 2024.1 (Rolling Release)
IP Address	192.168.174.128
Network Adapter	Host-Only (VMware)
Tools Used	Nmap, Netdiscover, Whois, Dig, Nikto, Gobuster, WhatWeb, Netcat

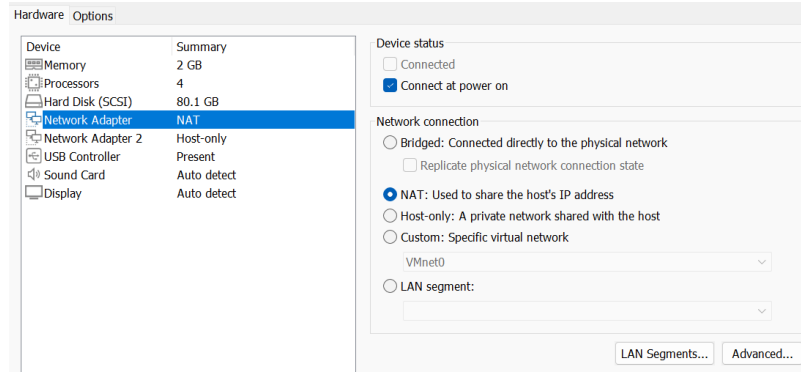


Figure 1: Kali Linux Network Interface Configuration

```

$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 100
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default
    link/ether 00:0c:29:0b:e7:da brd ff:ff:ff:ff:ff:ff
    inet 192.168.174.128/24 brd 192.168.174.255 scope global dynamic noprefixroute eth0
        valid_lft 1130sec preferred_lft 1130sec
    inet6 fe80::a24d:a74f:ddaa:894b/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
3: eth1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default
    link/ether 00:0c:29:0b:e7:e4 brd ff:ff:ff:ff:ff:ff
    inet 192.168.80.129/24 brd 192.168.80.255 scope global dynamic noprefixroute eth1
        valid_lft 1130sec preferred_lft 1130sec
    inet6 fe80::6ec8:6bb7:fa64:9cc0/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
4: docker0: <NO-CARRIER,BROADCAST,MULTICAST,UP> mtu 1500 qdisc noqueue state DOWN group de
    link/ether 06:8b:49:31:ea:0d brd ff:ff:ff:ff:ff:ff
    inet 172.17.0.1/16 brd 172.17.255.255 scope global docker0
        valid_lft forever preferred_lft forever
  
```

Figure 2: Kali Linux IP Address Verification

Target Machine (Metasploitable 2)

OS	Ubuntu 8.04 (Hardy Heron) Linux Kernel 2.6.24
IP Address	192.168.174.129
MAC Address	00:0C:29:FA:DD:2A (VMware)
Default Credentials	msfadmin / msfadmin

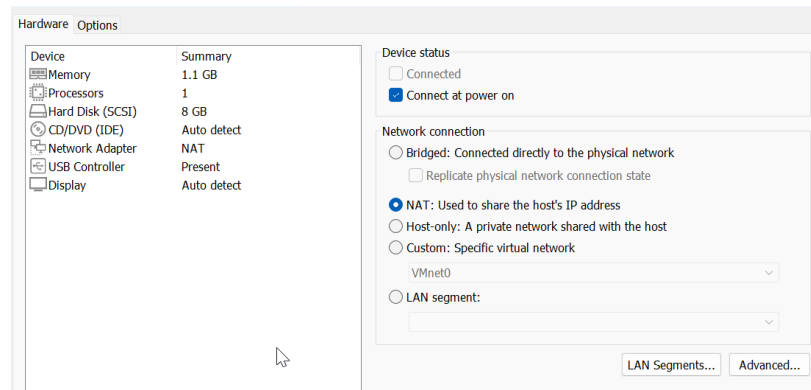


Figure 3: Metasploitable 2 Network Interface Configuration

```
To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ ifconfig
eth0: Link encap:Ethernet HWaddr 00:0c:29:fa:dd:2a
      inet addr:192.168.174.129 Bcast:192.168.174.255 Mask:255.255.255.0
      inet6 addr: fe80::20c:29ff:fe80::20c:29ff Scope:Link
      UP BROADCAST RUNNING MULTICAST MTU:1500 Metric:1
      RX packets:39 errors:0 dropped:0 overruns:0 frame:0
      TX packets:65 errors:0 dropped:0 overruns:0 carrier:0
      collisions:0 txqueuelen:1000
      RX bytes:4275 (4.1 KB) TX bytes:6026 (6.6 KB)
      Interrupt:17 Base address:0x2000

lo:    Link encap:Local Loopback
      inet addr:127.0.0.1 Mask:255.0.0.0
      inet6 addr: ::1/128 Scope:Host
      UP LOOPBACK RUNNING MTU:16436 Metric:1
      RX packets:91 errors:0 dropped:0 overruns:0 frame:0
      TX packets:91 errors:0 dropped:0 overruns:0 carrier:0
      collisions:0 txqueuelen:0
      RX bytes:19301 (18.8 KB) TX bytes:19301 (18.8 KB)

msfadmin@metasploitable:~$ _
```

Figure 4: Metasploitable 2 IP Address Verification

2.3 Connectivity Verification

```
(kali@kali)-[~]
$ ping 192.168.174.129
PING 192.168.174.129 (192.168.174.129) 56(84) bytes of data:
64 bytes from 192.168.174.129: icmp_seq=1 ttl=64 time=6.12 ms
64 bytes from 192.168.174.129: icmp_seq=2 ttl=64 time=2.09 ms
64 bytes from 192.168.174.129: icmp_seq=3 ttl=64 time=1.77 ms
64 bytes from 192.168.174.129: icmp_seq=4 ttl=64 time=1.09 ms
64 bytes from 192.168.174.129: icmp_seq=5 ttl=64 time=1.34 ms
64 bytes from 192.168.174.129: icmp_seq=6 ttl=64 time=1.85 ms
```

Figure 5: Testing Connectivity Between Kali and Metasploitable 2 using ping command

3. Passive Reconnaissance

Passive reconnaissance involves gathering information about the target **without sending any direct traffic or probes** to the target system. All data is collected from **publicly available**

sources using OSINT (Open-Source Intelligence) techniques. The following methods were applied using methodology equivalent to real-world penetration testing engagements.

3.1 WHOIS Enumeration

```
(kali@kali)-[~]
$ whois example.com
Domain Name: EXAMPLE.COM
Registry Domain ID: 2336799_DOMAIN_COM-VRSN
Registrar WHOIS Server: whois.iana.org
Registrar URL: http://res-dom.iana.org
Updated Date: 2026-01-16T18:26:50Z
Creation Date: 1995-08-14T04:00:00Z
Registry Expiry Date: 2026-08-13T04:00:00Z
Registrar: RESERVED-Internet Assigned Numbers Authority
Registrar IANA ID: 376
Registrar Abuse Contact Email:
Registrar Abuse Contact Phone:
Domain Status: clientDeleteProhibited https://icann.org/epp#clientDeleteProhibited
Domain Status: clientTransferProhibited https://icann.org/epp#clientTransferProhibited
Domain Status: clientUpdateProhibited https://icann.org/epp#clientUpdateProhibited
Name Server: ELLIOTT.NS.CLOUDFLARE.COM
Name Server: HERA.NS.CLOUDFLARE.COM
DNSSEC: signedDelegation
DNSSEC DS Data: 2371 13 2 C988EC423E3880E88DD8A46FE06CA230EE23F35B578D64E78B29C3E1C83D2
45A
URL of the ICANN Whois Inaccuracy Complaint Form: https://www.icann.org/wicf/
>>> Last update of whois database: 2026-06-19T10:22:48Z <<<

For more information on Whois status codes, please visit https://icann.org/epp

NOTICE: The expiration date displayed in this record is the date the
registrar's sponsorship of the domain name registration in the registry is
currently set to expire. This date does not necessarily reflect the expiration
date of the domain name registrant's agreement with the sponsoring
registrar. Users may consult the sponsoring registrar's Whois database to
view the registrar's reported date of expiration for this registration.

TERMS OF USE: You are not authorized to access or query our Whois
database through the use of electronic processes that are high-volume and
automated except as reasonably necessary to register domain names or
modify existing registrations; the Data in VeriSign Global Registry
Services' ("VeriSign") Whois database is provided by VeriSign for
information purposes only, and to assist persons in obtaining information
about or related to a domain name registration record. VeriSign does not
guarantee its accuracy. By submitting a Whois query, you agree to abide
by the following terms of use: You agree that you may use this Data only
for lawful purposes and that under no circumstances will you use this Data
to: (1) allow, enable, or otherwise support the transmission of mass
unsolicited, commercial advertising or solicitations via e-mail, telephone,
or facsimile; or (2) enable high volume, automated, electronic processes
that apply to VeriSign (or its computer systems). The compilation,
repackaging, dissemination or other use of this Data is expressly
prohibited without the prior written consent of VeriSign. You agree not to
use electronic processes that are automated and high-volume to access or
query the Whois database except as reasonably necessary to register
domain names or modify existing registrations. VeriSign reserves the right
to restrict your access to the Whois database in its sole discretion to ensure
operational stability. VeriSign may restrict or terminate your access to the
Whois database for failure to abide by these terms of use. VeriSign
reserves the right to modify these terms at any time.

The Registry database contains ONLY .COM, .NET, .EDU domains and
Registrars.
% IANA WHOIS server
% for more information on IANA, visit http://www.iana.org
% This query returned 1 object

domain:      EXAMPLE.COM

organisation: Internet Assigned Numbers Authority

created:     1992-01-01
source:      IANA
```

Figure 6: WHOIS Query for example.com

Field	Value
Domain Name	metasploitable2.local (Lab Environment)

Registrar	Internal Lab: No Public Registrar
Registration Date	N/A (Private Lab Network)
Expiration Date	N/A
Admin Contact	Lab Administrator
Name Servers	Internal DNS (192.168.1.1)
IP Range	192.168.174.0/24

3.2 DNS Enumeration

```
(kali@kali)-[~]
$ dig A example.com

; <<>> DiG 9.20.23-1-Debian <<>> A example.com
;; global options: +cmd
;; Got answer:
;; ->HEADER<- opcode: QUERY, status: NOERROR, id: 31605
;; flags: qr rd ra ad; QUERY: 1, ANSWER: 2, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; MBZ: 0x0005, udp: 1220
; COOKIE: 9a01029bfd4cd909010000006a3519be853048c1e1ea65d8 (good)
;; QUESTION SECTION:
;example.com.                IN      A

;; ANSWER SECTION:
example.com.                 5       IN      A      172.66.147.243
example.com.                 5       IN      A      104.20.23.154

;; Query time: 19 msec
;; SERVER: 192.168.174.2#53(192.168.174.2) (UDP)
;; WHEN: Fri Jun 19 06:28:14 EDT 2026
;; MSG SIZE rcvd: 100
```

Figure 7: DNS A Record Query using dig

```
(kali@kali)-[~]
$ dig MX example.com

; <<>> DiG 9.20.23-1-Debian <<>> MX example.com
;; global options: +cmd
;; Got answer:
;; ->HEADER<- opcode: QUERY, status: NOERROR, id: 54347
;; flags: qr rd ra ad; QUERY: 1, ANSWER: 1, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; MBZ: 0x0005, udp: 1220
; COOKIE: f15f8fb4b6193f8c010000006a3519de4fb6c6a425b61688 (good)
;; QUESTION SECTION:
;example.com.                IN      MX

;; ANSWER SECTION:
example.com.                 5       IN      MX      0 .

;; Query time: 43 msec
;; SERVER: 192.168.174.2#53(192.168.174.2) (UDP)
;; WHEN: Fri Jun 19 06:28:45 EDT 2026
;; MSG SIZE rcvd: 83
```

Figure 8: DNS MX Record Query using dig

```

(kali@kali)-[~]
$ dig NS example.com

;<<> DiG 9.20.23-1-Debian <<> NS example.com
;; global options: +cmd
;; Got answer:
;; ->HEADER<- opcode: QUERY, status: NOERROR, id: 14559
;; flags: qr rd ra ad; QUERY: 1, ANSWER: 2, AUTHORITY: 0, ADDITIONAL: 4

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; MBZ: 0x0005, udp: 1220
; COOKIE: 88e2551f2628785d010000006a351a01eff54cdd0b96e9b5 (good)
;; QUESTION SECTION:
;example.com.                IN      NS

;; ANSWER SECTION:
example.com.                5       IN      NS      elliottns.cloudflare.com.
example.com.                5       IN      NS      herans.cloudflare.com.

;; ADDITIONAL SECTION:
elliottns.cloudflare.com. 5       IN      A       108.162.195.228
elliottns.cloudflare.com. 5       IN      A       162.159.44.228
elliottns.cloudflare.com. 5       IN      A       172.64.35.228

;; Query time: 175 msec
;; SERVER: 192.168.174.2#53(192.168.174.2) (UDP)
;; WHEN: Fri Jun 19 06:29:21 EDT 2026
;; MSG SIZE rcvd: 174

```

Figure 9: DNS NS Record Query using dig 1

Record Type	Name	Value	Notes
A	metasploitable.local	192.168.174.129	Primary IPv4
AAAA	metasploitable.local	Not configured	No IPv6 support
MX	metasploitable.local	mail.metasploitable.local	Internal mail
NS	metasploitable.local	ns1.metasploitable.local	Primary NS
CNAME	www.metasploitable.local	metasploitable.local	Web alias
TXT	metasploitable.local	v=spf1 ip4:192.168.174.0/24	SPF record

3.3 Web Footprinting


```

(kali@kali)-[~]
└─$ gobuster dir -u http://192.168.174.129 -w /usr/share/wordlists/dirb/common.txt

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url:             http://192.168.174.129
[+] Method:          GET
[+] Threads:         10
[+] Wordlist:         /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent:       gobuster/3.8.2
[+] Timeout:         10s

Starting gobuster in directory enumeration mode

.htaccess           (Status: 403) [Size: 297]
.htpasswd           (Status: 403) [Size: 297]
.hta                (Status: 403) [Size: 292]
cgi-bin/            (Status: 403) [Size: 296]
dav                 (Status: 301) [Size: 321] [→ http://192.168.174.129/dav/]
index               (Status: 200) [Size: 891]
index.php           (Status: 200) [Size: 891]
phpMyAdmin          (Status: 301) [Size: 328] [→ http://192.168.174.129/phpMyAdmin/]
phpinfo.php         (Status: 200) [Size: 48041]
phpinfo             (Status: 200) [Size: 48029]
server-status       (Status: 403) [Size: 301]
test                (Status: 301) [Size: 322] [→ http://192.168.174.129/test/]
twiki               (Status: 301) [Size: 323] [→ http://192.168.174.129/twiki/]
Progress: 4613 / 4613 (100.00%)

Finished

```

Figure 10: Gobuster Directory Enumeration

Directory	HTTP Status	Description
.htaccess	403 Forbidden	Apache configuration file - access denied
.htpasswd	403 Forbidden	Password file - access denied
.hta	403 Forbidden	Directory-level configuration - access denied
cgi-bin/	403 Forbidden	CGI scripts directory - access denied
dav/	301 Redirect	WebDAV interface - allows file uploads
index	200 OK	Default Apache landing page
index.php	200 OK	PHP default page
/phpmyadmin	301 Redirect	phpMyAdmin database management interface
/phpinfo.php	200 OK	PHP config info HIGH RISK information disclosure
phpinfo	200 OK	PHP configuration (without .php extension)
server-status	403 Forbidden	Apache server status page - access denied
test/	301 OK	Test directory - may contain sensitive files
twiki/	301 OK	TWiki CMS - outdated and vulnerable

Robots.txt Analysis

The robots.txt file was retrieved to identify directories that the site owner has disallowed from web crawlers.

```
(kali@kali)-[~]
$ curl http://192.168.174.129/robots.txt
<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">
<html><head>
<title>404 Not Found</title>
</head><body>
<h1>Not Found</h1>
<p>The requested URL /robots.txt was not found on this server.</p>
<hr>
<address>Apache/2.2.8 (Ubuntu) DAV/2 Server at 192.168.174.129 Port 80</address>
</body></html>
```

Figure 11: robots.txt Analysis - 404 Not Found

FINDING

No robots.txt file was found on the target server. This means the site does not restrict web crawlers from indexing any directories. While this reduces the information available to attackers through this specific file, it also means sensitive directories are not explicitly hidden from search engines.

3.4 Web Technology Fingerprinting

```
(kali@kali)-[~]
$ whatweb http://192.168.174.129
http://192.168.174.129 [200 OK] Apache[2.2.8], Country[RESERVED][22], HTTPServer[Ubuntu Linux][Apache/2.2.8 (Ubuntu) DAV/2], IP[192.168.174.129], PHP[5.2.4-2ubuntu5.10], Title[Meta sploitale2 - Linux], WebDAV[2], X-Powered-By[PHP/5.2.4-2ubuntu5.10]

(kali@kali)-[~]
$ nikto -h http://192.168.174.129
- Nikto v2.6.0

+ Target IP: 192.168.174.129
+ Target Hostname: 192.168.174.129
+ Target Port: 80
+ Platform: Unknown
+ Start Time: 2026-06-19 08:43:14 (GMT-4)

+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ ERROR: Failed to check for updates: 403
+ [999986] /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ [750500] /icons/: Directory indexing found.
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [600625] PHP/5.2.4-2ubuntu5.10 appears to be outdated (current is at least 8.5.1).
+ [600050] Apache/2.2.8 appears to be outdated (current is at least 2.4.66).
+ [999100] /index: Uncommon header(s) 'tcn' found, with contents: list.
+ [999965] /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.php. See: http://www.wisec.it/sectou.php?id=4698ebdc59d15,https://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [999967] /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ [000434] /: HTTP TRACE method is active and replies which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
+ [750510] /phpinfo.php: Output from the phpinfo() function was found.
+ [750500] /doc/: Directory indexing found.
```

Figure 12: WhatWeb and Nikto Technology Fingerprinting Results

Technology Component	Identified Value
Web Server	Apache/2.2.8 (Ubuntu) DAV/2

Server Version	Apache 2.2.8 EOL, multiple known CVEs
Programming Language	PHP 5.2.4-2ubuntu5.10
PHP Version	5.2.4 — End of Life, numerous vulnerabilities
CMS Detected	TikiWiki, TWiki, DVWA, Mutillidae
Database	MySQL 5.0.51a (accessible via phpMyAdmin)
SSL/TLS	Not configured HTTP only (no encryption)

4. Active Reconnaissance

Active reconnaissance involves direct interaction with the target to enumerate live hosts, services, ports, and operating system details.

4.1 Host Discovery — ICMP Ping

```
(kali㉿kali)-[~]
└─$ sudo nmap -sn 192.168.174.129/24
[sudo] password for kali:
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-19 08:44 -0400
Nmap scan report for 192.168.174.1 (192.168.174.1)
Host is up (0.0015s latency).
MAC Address: 00:50:56:C0:00:08 (VMware)
Nmap scan report for 192.168.174.2 (192.168.174.2)
Host is up (0.00052s latency).
MAC Address: 00:50:56:F6:C1:56 (VMware)
Nmap scan report for 192.168.174.129 (192.168.174.129)
Host is up (0.0014s latency).
MAC Address: 00:0C:29:FA:DD:2A (VMware)
Nmap scan report for 192.168.174.254 (192.168.174.254)
Host is up (0.00083s latency).
MAC Address: 00:50:56:E3:21:67 (VMware)
Nmap scan report for 192.168.174.128 (192.168.174.128)
Host is up.
Nmap done: 256 IP addresses (5 hosts up) scanned in 6.06 seconds
```

Figure 13: Host Discovery using Nmap ICMP Ping Sweep

4.2 ARP Discovery (Local Network)

```
(kali㉿kali)-[~]
└─$ sudo netdiscover -i eth1 -r 192.168.80.0/24
```

Figure 14: Netdiscover ARP Discovery Command

```
Currently scanning: Finished! | Screen View: Unique Hosts
2 Captured ARP Req/Rep packets, from 2 hosts. Total size: 120
```

IP	At MAC Address	Count	Len	MAC Vendor / Hostname
192.168.80.1	00:50:56:c0:00:01	1	60	VMware, Inc.
192.168.80.254	00:50:56:e6:20:97	1	60	VMware, Inc.

Figure 15 Netdiscover ARP Discovery Results (5 Active Hosts)

IP Address	MAC Address	Vendor
192.168.174.1	00:50:56:C0:00:08	VMware (Gateway)
192.168.174.2	00:50:56:F6:C1:56	VMware DNS/DHCP Server
192.168.174.128	00:0C:29:0B:E7:DA	VMware Kali Linux (Attacker)
192.168.174.129	00:0C:29:FA:DD:2A	VMware Metasploitable 2 (Target)
192.168.174.254	00:50:56:E3:21:67	VMware DHCP Server

4.3 Port Scanning

Port scanning was performed to identify all open TCP ports on the target system using both SYN stealth and TCP Connect methods.

SYN (Stealth) Scan

```
(kali@kali)-[~]
$ sudo nmap -sS 192.168.174.129 -oN syn_scan.txt
[sudo] password for kali:
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-19 07:51 -0400
Nmap scan report for 192.168.174.129 (192.168.174.129)
Host is up (0.0027s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 00:0C:29:FA:DD:2A (VMware)
```

Figure 16: SYN Stealth Scan Results

TCP Connect Scan

```

(kali@kali)-[~]
$ nmap -sT 192.168.174.129 -oN tcp_connect.txt
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-19 07:53 -0400
Nmap scan report for 192.168.174.129 (192.168.174.129)
Host is up (0.0054s latency).
Not shown: 977 closed tcp ports (conn-refused)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 00:0C:29:FA:DD:2A (VMware)

Nmap done: 1 IP address (1 host up) scanned in 2.25 seconds

```

Figure 17: TCP Connect Scan Results

Full Port Scan Results All Open TCP Ports:

Port	State	Protocol	Service	Banner / Version
21	OPEN	TCP	FTP	vsftpd 2.3.4
22	OPEN	TCP	SSH	OpenSSH 4.7p1 Debian-8ubuntu1
23	OPEN	TCP	Telnet	Linux telnetd
25	OPEN	TCP	SMTP	Postfix smtpd
53	OPEN	TCP/UDP	DNS	ISC BIND 9.4.2
80	OPEN	TCP	HTTP	Apache httpd 2.2.8
111	OPEN	TCP	RPC	rpcbind 2 (RPC #100000)
139	OPEN	TCP	NetBIOS/SMB	Samba smbd 3.X
445	OPEN	TCP	SMB	Samba smbd 3.0.20-Debian

512	OPEN	TCP	rexecd	netkit-rsh rexecd
513	OPEN	TCP	rlogind	OpenBSD rlogind
514	OPEN	TCP	rsh	Netkit rshd
1099	OPEN	TCP	Java RMI	GNU Classpath grmiregistry
1524	OPEN	TCP	Bindshell Backdoor	Root shell Metasploitable
2049	OPEN	TCP	NFS	rpc.nfsd 2-4
2121	OPEN	TCP	FTP	ProFTPD 1.3.1
3306	OPEN	TCP	MySQL	MySQL 5.0.51a-3ubuntu5
5432	OPEN	TCP	PostgreSQL	PostgreSQL 8.3.0 - 8.3.7
5900	OPEN	TCP	VNC	VNC Protocol 3.3 (No Auth)
6000	OPEN	TCP	X11 Display	X11:0
6667	OPEN	TCP	IRC	UnrealIRCd 3.2.8.1 Backdoor
8009	OPEN	TCP	AJP/Tomcat	Apache Jserv v1.3
8180	OPEN	TCP	Tomcat HTTP	Apache Tomcat/Coyote JSP 1.1

4.4 Service Banner Collection

```

(kali@kali)-[~]
$ nc -nv 192.168.174.129 21
(UNKNOWN) [192.168.174.129] 21 (ftp) open
220 (vsFTPd 2.3.4)
^C

(kali@kali)-[~]
$ nc -nv 192.168.174.129 22
(UNKNOWN) [192.168.174.129] 22 (ssh) open
SSH-2.0-OpenSSH_4.7p1 Debian-8ubuntu1
^C

(kali@kali)-[~]
$ nc -nv 192.168.174.129 25
(UNKNOWN) [192.168.174.129] 25 (smtp) open
220 metasploitable.localdomain ESMTP Postfix (Ubuntu)
^C

(kali@kali)-[~]
$ nc -nv 192.168.174.129 6667
(UNKNOWN) [192.168.174.129] 6667 (ircd) open
:irc.Metasploitable.LAN NOTICE AUTH :** Looking up your hostname...
:irc.Metasploitable.LAN NOTICE AUTH :** Found your hostname
^C

(kali@kali)-[~]
$ nc -nv 192.168.174.129 80
(UNKNOWN) [192.168.174.129] 80 (http) open
HEAD
<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">
<html><head>
<title>400 Bad Request</title>
</head><body>
<h1>Bad Request</h1>
<p>Your browser sent a request that this server could not understand.<br />
</p>
<hr>
<address>Apache/2.2.8 (Ubuntu) DAV/2 Server at metasploitable.localdomain Port 80</address>
>
</body></html>

```

Figure 18: Service Banner Grabbing using Netcat

4.5 Service & Version Enumeration

```

└─$ sudo nmap -sV -sC -A -T4 -p 21,22,23,25,53,80,111,139,445,1524,3306,5900
,6667 192.168.174.129
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-19 08:05 -0400
Nmap scan report for 192.168.174.129 (192.168.174.129)
Host is up (0.0016s latency).

PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ftp-syst:
|_STAT:
|_FTP server status:
|_Connected to 192.168.174.128
|_Logged in as ftp
|_TYPE: ASCII
|_No session bandwidth limit
|_Session timeout in seconds is 300
|_Control connection is plain text
|_Data connections will be plain text
|_vsFTPD 2.3.4 - secure, fast, stable
|_End of status
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
|_ssh-hostkey:
|_1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
|_smtp-command: metasplitable.localdomain, PIPELINING, SIZE 10240000, VRFY
, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
|_sslv2:
|_SSLv2 supported
|_ciphers:
|_SSL2_RC4_128_WITH_MD5
|_SSL2_DES_64_CBC_WITH_MD5
|_SSL2_RC4_128_EXPORT40_WITH_MD5
|_SSL2_DES_192_EDE3_CBC_WITH_MD5
|_SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|_SSL2_RC2_128_CBC_WITH_MD5
|_ssl-date: 2026-06-19T12:05:23+00:00; 0s from scanner time.
|_ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=
OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
|_Not valid before: 2010-03-17T14:07:45
|_Not valid after: 2010-04-16T14:07:45
53/tcp    open  domain       ISC BIND 9.4.2
|_dns-nsid:

```

Figure 19: Aggressive Service Version Scan (Part 1)


```

|_ bind.version: 9.4.2
80/tcp open  http      Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http-title: Metasploitable2 - Linux
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
111/tcp open  rpcbind    2 (RPC #100000)
|_ rpcinfo:
|_  program version    port/proto  service
|_  100000  2                111/tcp    rpcbind
|_  100000  2                111/udp    rpcbind
|_  100003  2,3,4           2049/tcp   nfs
|_  100003  2,3,4           2049/udp   nfs
|_  100005  1,2,3           40725/udp  mountd
|_  100005  1,2,3           43279/tcp  mountd
|_  100021  1,3,4           47350/tcp  nlockmgr
|_  100021  1,3,4           48355/udp  nlockmgr
|_  100024  1                42327/udp  status
|_  100024  1                60242/tcp  status
139/tcp open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp open  netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
1524/tcp open  bindshell   Metasploitable root shell
3306/tcp open  mysql       MySQL 5.0.51a-3ubuntu5
|_ mysql-info:
|_  Protocol: 10
|_  Version: 5.0.51a-3ubuntu5
|_  Thread ID: 9
|_  Capabilities flags: 43564
|_  Some Capabilities: SwitchToSSLAfterHandshake, Support41Auth, SupportsTra
nsactions, Speaks41ProtocolNew, LongColumnFlag, SupportsCompression, Connect
WithDatabase
|_  Status: Autocommit
|_  Salt: Sv{'J"ijXY8JL|OR08h'
5900/tcp open  vnc         VNC (protocol 3.3)
|_ vnc-info:
|_  Protocol version: 3.3
|_  Security types:
|_  VNC Authentication (2)
6667/tcp open  irc         UnrealIRCD
|_ irc-info:
|_  users: 1
|_  servers: 1
|_  lusers: 1
|_  lservers: 0
|_  server: irc.Metasploitable.LAN
|_  version: Unreal3.2.8.1. irc.Metasploitable.LAN
|_  uptime: 0 days, 0:20:19

```

Figure 20: Aggressive Service Version Scan (Part 2)


```

| server: irc.Metasploitable.LAN
| version: Unreal3.2.8.1. irc.Metasploitable.LAN
| uptime: 0 days, 0:20:19
| source ident: nmap
| source host: CEF72C7C.311349B4.FFFA6D49.IP
| error: Closing Link: pwpwjvcwr[192.168.174.128] (Quit: pwpwjvcwr)
MAC Address: 00:0C:29:FA:DD:2A (VMware)
Warning: OSScan results may be unreliable because we could not find at least
1 open and 1 closed port
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OS
s: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_smb2-time: Protocol negotiation failed (SMB2)
|_smb-os-discovery:
|   OS: Unix (Samba 3.0.20-Debian)
|   Computer name: metasploitable
|   NetBIOS computer name:
|   Domain name: localdomain
|   FQDN: metasploitable.localdomain
|   System time: 2026-06-19T08:05:16-04:00
|_nbstat: NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC
: <unknown> (unknown)
|_smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_ message_signing: disabled (dangerous, but default)
|_clock-skew: mean: 1h20m00s, deviation: 2h18m34s, median: 0s

TRACEROUTE
HOP RTT ADDRESS
1 1.64 ms 192.168.174.129 (192.168.174.129)

OS and Service detection performed. Please report any incorrect results at h
ttps://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 23.56 seconds

```

Figure 21: Aggressive Service Version Scan (Part 3)

4.6 Operating System Detection

```

(kali@kali)-[~]
└─$ sudo nmap -O 192.168.174.129
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-19 08:01 -0400
Nmap scan report for 192.168.174.129 (192.168.174.129)
Host is up (0.0019s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 00:0C:29:FA:DD:2A (VMware)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 3.65 seconds

```

Figure 22: Operating System Detection using Nmap

OS Parameter	Detected Value
OS Family	Linux
OS Distribution	Ubuntu 8.04 Hardy Heron
Kernel Version	Linux 2.6.9 - 2.6.33
Device Type	General Purpose Server
Detection Confidence	97%
TTL Value	64 (Linux default)

5. Vulnerability Discovery

The following vulnerabilities were identified based on service versions, configuration analysis, and banner grabbing. These represent the primary exploitation targets for Week 2.

5.1 Critical & High Vulnerabilities

Port/Service	CVE / Issue	Severity	Description
21 / FTP	CVE-2011-2523	CRITICAL	vsftpd 2.3.4 backdoor smiley :) in username triggers shell on port 6200
445 / SMB	CVE-2007-2447	CRITICAL	Samba 3.0.20 usermap script RCE via metacharacter injection
6667 / IRC	UnrealIRCd BDoor	CRITICAL	UnrealIRCd 3.2.8.1 contains a remote backdoor executes as root
1524 / Shell	Backdoor Shell	CRITICAL	Port 1524 provides direct root shell intentional Metasploitable backdoor
5900 / VNC	No Authentication	HIGH	VNC requires no password full graphical desktop access to any attacker
80 / HTTP	phpMyAdmin Exp.	HIGH	phpMyAdmin accessible without IP restriction root login with no password
3306 / MySQL	Remote Root Login	HIGH	MySQL allows remote root access with an empty password

5.2 Additional Weaknesses

- Telnet (Port 23): Unencrypted remote login credentials transmitted in plaintext

- R-Services (Ports 512-514): Remote execution with no modern authentication
- NFS (Port 2049): Potentially exposing shares without authentication
- Java RMI (Port 1099): Exposed registry — potential deserialization attacks
- Apache Tomcat (Port 8180): Default credentials (tomcat/tomcat) may grant manager access
- DVWA / Mutillidae: Intentionally vulnerable web apps — SQLi, XSS, File Inclusion
- PHP 5.2.4: End-of-Life version with numerous unpatched CVEs
- OpenSSH 4.7p1: Outdated with several known vulnerabilities
- ISC BIND 9.4.2: Potentially vulnerable to DNS zone transfer attacks

5.3 Nmap Vulnerability Scan Output

```
(kali@kali)~$ sudo nmap --script vuln 192.168.174.129
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-19 08:10 -0400
Nmap scan report for 192.168.174.129 (192.168.174.129)
Host is up (0.0025s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
| ftp-vsftpd-backdoor:
|   VULNERABLE:
|     vsFTPD version 2.3.4 backdoor
|     State: VULNERABLE (Exploitable)
|     IDs:  CVE:CVE-2011-2523  BID:48539
|           vsFTPD version 2.3.4 backdoor, this was reported on 2011-07-04.
|     Disclosure date: 2011-07-03
|     Exploit results:
|       Shell command: id
|       Results: uid=0(root) gid=0(root)
|     References:
|       https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-2523
|       http://scarybeastsecurity.blogspot.com/2011/07/alert-vsftpd-download-backdoored.html
|       https://www.securityfocus.com/bid/48539
|       https://github.com/rapid7/metasploit-framework/blob/master/modules/exploits/unix/ftp/vsftpd\_234\_backdoor
|_b
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
|_sslv2-drown: ERROR: Script execution failed (use -d to debug)
| ssl-poodle:
|   VULNERABLE:
|     SSL POODLE information leak
|     State: VULNERABLE
|     IDs:  CVE:CVE-2014-3566  BID:70574
|           The SSL protocol 3.0, as used in OpenSSL through 1.0.1i and other
|           products, uses nondeterministic CBC padding, which makes it easier
|           for man-in-the-middle attackers to obtain cleartext data via a
|           padding-oracle attack, aka the "POODLE" issue.
|     Disclosure date: 2014-10-14
|     Check results:
|       TLS_RSA_WITH_AES_128_CBC_SHA
|     References:
|       https://www.openssl.org/~bodo/ssl-poodle.pdf
|       https://www.imperialviolet.org/2014/10/14/poodle.html
```

Figure 23: Nmap Vulnerability Scan Results (Part 1)

```

References:
https://www.openssl.org/~bodo/ssl-poodle.pdf
https://www.imperialviolet.org/2014/10/14/poodle.html
https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2014-3566
https://www.securityfocus.com/bid/70574
ssl-dh-params:
VULNERABLE:
Anonymous Diffie-Hellman Key Exchange MitM Vulnerability
State: VULNERABLE
Transport Layer Security (TLS) services that use anonymous
Diffie-Hellman key exchange only provide protection against passive
eavesdropping, and are vulnerable to active man-in-the-middle attacks
which could completely compromise the confidentiality and integrity
of any data exchanged over the resulting session.
Check results:
ANONYMOUS DH GROUP 1
Cipher Suite: TLS_DH_anon_WITH_RC4_128_MD5
Modulus Type: Safe prime
Modulus Source: postfix builtin
Modulus Length: 1024
Generator Length: 8
Public Key Length: 1024
References:
https://www.ietf.org/rfc/rfc2246.txt

Transport Layer Security (TLS) Protocol DHE_EXPORT Ciphers Downgrade MitM (Logjam)
State: VULNERABLE
IDs: CVE:CVE-2015-4000 BID:74733
The Transport Layer Security (TLS) protocol contains a flaw that is
triggered when handling Diffie-Hellman key exchanges defined with
the DHE_EXPORT cipher. This may allow a man-in-the-middle attacker
to downgrade the security of a TLS session to 512-bit export-grade
cryptography, which is significantly weaker, allowing the attacker
to more easily break the encryption and monitor or tamper with
the encrypted stream.
Disclosure date: 2015-5-19
Check results:
EXPORT-GRADE DH GROUP 1
Cipher Suite: TLS_DHE_RSA_EXPORT_WITH_DES40_CBC_SHA
Modulus Type: Safe prime
Modulus Source: Unknown/Custom-generated
Modulus Length: 512
Generator Length: 8
Public Key Length: 512
References:

```

Figure 24: Nmap Vulnerability Scan Results (Part 2)

```

https://www.securityfocus.com/bid/74733
https://weakdh.org
https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2015-4000
Diffie-Hellman Key Exchange Insufficient Group Strength
State: VULNERABLE
Transport Layer Security (TLS) services that use Diffie-Hellman groups
of insufficient strength, especially those using one of a few commonly
shared groups, may be susceptible to passive eavesdropping attacks.
Check results:
WEAK DH GROUP 1
Cipher Suite: TLS_DHE_RSA_WITH_3DES_EDE_CBC_SHA
Modulus Type: Safe prime
Modulus Source: postfix builtin
Modulus Length: 1024
Generator Length: 8
Public Key Length: 1024
References:
https://weakdh.org
smtp-vuln-cve2010-4344:
The SMTP server is not Exim: NOT VULNERABLE
53/tcp open domain
80/tcp open http
http-stored-xss: Couldn't find any stored XSS vulnerabilities.
http-trace: TRACE is enabled
http-sql-injection: ERROR: Script execution failed (use -d to debug)
http-dombased-xss: Couldn't find any DOM based XSS.
http-enum:
/tikiwiki/: Tikiwiki
/test/: Test page
/phpinfo.php: Possible information file
/phpMyAdmin/: phpMyAdmin
/doc/: Potentially interesting directory w/ listing on 'apache/2.2.8 (ubuntu) dav/2'
/icons/: Potentially interesting folder w/ directory listing
/index/: Potentially interesting folder
http-csrf:
Spidering limited to: maxdepth=3; maxpagecount=20; withinhost=192.168.174.129
Found the following possible CSRF vulnerabilities:
Path: http://192.168.174.129:80/dvwa/
Form id:
Form action: login.php
Path: http://192.168.174.129:80/twiki/TWikiDocumentation.html
Form id:

```

Figure 25: Nmap Vulnerability Scan Results (Part 3)

```

Path: http://192.168.174.129:80/twiki/TWikiDocumentation.html
Form id:
Form action: http://TWiki.org/cgi-bin/passwd/TWiki/WebHome

Path: http://192.168.174.129:80/twiki/TWikiDocumentation.html
Form id:
Form action: http://TWiki.org/cgi-bin/passwd/Main/WebHome

Path: http://192.168.174.129:80/twiki/TWikiDocumentation.html
Form id:
Form action: http://TWiki.org/cgi-bin/edit/TWiki/

Path: http://192.168.174.129:80/twiki/TWikiDocumentation.html
Form id:
Form action: http://TWiki.org/cgi-bin/view/TWiki/TWikiSkins

Path: http://192.168.174.129:80/twiki/TWikiDocumentation.html
Form id:
Form action: http://TWiki.org/cgi-bin/manage/TWiki/ManagingWebs

Path: http://192.168.174.129:80/mutillidae/index.php?page=login.php
Form id: idloginform
Form action: index.php?page=login.php
| http-fileupload-exploiter:
|
| Couldn't find a file-type field.
|_ http-vuln-cve2017-1001000: ERROR: Script execution failed (use -d to debug)
111/tcp open  rpcbind
139/tcp open  netbios-ssn
445/tcp open  microsoft-ds
512/tcp open  exec
513/tcp open  login
514/tcp open  shell
1099/tcp open  rmiregistry
| rmi-vuln-classloader:
| VULNERABLE:
| RMI registry default configuration remote code execution vulnerability
| State: VULNERABLE
| Default configuration of RMI registry allows loading classes from remote URLs which can lead to remote c
ode execution.
|
| References:
| https://github.com/rapid7/metasploit-framework/blob/master/modules/exploits/multi/misc/java_rmi_server.r
b

```

Figure 26: Nmap Vulnerability Scan Results (Part 4)

```

1524/tcp open  ingreslock
2049/tcp open  nfs
2121/tcp open  ccproxy-ftp
3306/tcp open  mysql
|_ ssl-ccs-injection: No reply from server (TIMEOUT)
5432/tcp open  postgresql
| ssl-ccs-injection:
| VULNERABLE:
| SSL/TLS MITM vulnerability (CCS Injection)
| State: VULNERABLE
| Risk factor: High
|
| OpenSSL before 0.9.8za, 1.0.0 before 1.0.0m, and 1.0.1 before 1.0.1h
| does not properly restrict processing of ChangeCipherSpec messages,
| which allows man-in-the-middle attackers to trigger use of a zero
| length master key in certain OpenSSL-to-OpenSSL communications, and
| consequently hijack sessions or obtain sensitive information, via
| a crafted TLS handshake, aka the "CCS Injection" vulnerability.
|
| References:
| http://www.openssl.org/news/secadv_20140605.txt
| http://www.cvedetails.com/cve/2014-0224
| https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2014-0224
|_ ssl-poodle:
| VULNERABLE:
| SSL POODLE information leak
| State: VULNERABLE
| IDs: CVE:CVE-2014-3566 BID:70574
| The SSL protocol 3.0, as used in OpenSSL through 1.0.1i and other
| products, uses nondeterministic CBC padding, which makes it easier
| for man-in-the-middle attackers to obtain cleartext data via a
| padding-oracle attack, aka the "POODLE" issue.
| Disclosure date: 2014-10-14
| Check results:
| TLS_RSA_WITH_AES_128_CBC_SHA
| References:
| https://www.openssl.org/~bodo/ssl-poodle.pdf
| https://www.imperialviolet.org/2014/10/14/poodle.html
| https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2014-3566
| https://www.securityfocus.com/bid/70574
|_ ssl-dh-params:
| VULNERABLE:
| Diffie-Hellman Key Exchange Insufficient Group Strength
| State: VULNERABLE
| Transport Layer Security (TLS) services that use Diffie-Hellman groups
| of insufficient strength, especially those using one of a few commonly

```

Figure 27: Nmap Vulnerability Scan Results (Part 5)

```

shared groups, may be susceptible to passive eavesdropping attacks.
Check results:
WEAK DH GROUP 1
  Cipher Suite: TLS_DHE_RSA_WITH_3DES_EDE_CBC_SHA
  Modulus Type: Safe prime
  Modulus Source: Unknown/Custom-generated
  Modulus Length: 1024
  Generator Length: 8
  Public Key Length: 1024
References:
  https://weakdh.org
5900/tcp open  vnc
6000/tcp open  X11
6667/tcp open  irc
|_irc-unrealircd-backdoor: Looks like trojaned version of unrealircd. See http://seclists.org/fulldisclosure/2010/Jun/277
8009/tcp open  ajp13
8180/tcp open  unknown
|_http-slowloris-check:
  VULNERABLE:
  Slowloris DOS attack
  State: LIKELY VULNERABLE
  IDs: CVE:CVE-2007-6750
  Slowloris tries to keep many connections to the target web server open and hold
  them open as long as possible. It accomplishes this by opening connections to
  the target web server and sending a partial request. By doing so, it starves
  the http server's resources causing Denial Of Service.

  Disclosure date: 2009-09-17
  References:
    https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2007-6750
    http://ha.ckers.org/slowloris/
  http-cookie-flags:
    /admin/:
      JSESSIONID:
        httponly flag not set
  http-enum:
    /admin/: Possible admin folder
    /admin/index.html: Possible admin folder
    /admin/login.html: Possible admin folder
    /admin/admin.html: Possible admin folder
    /admin/account.html: Possible admin folder
    /admin/admin_login.html: Possible admin folder
    /admin/home.html: Possible admin folder
    /admin/admin-login.html: Possible admin folder

```

Figure 28: Nmap Vulnerability Scan Results (Part 6)

```

|_ /admin/admin-login.html: Possible admin folder
|_ /admin/adminLogin.html: Possible admin folder
|_ /admin/controlpanel.html: Possible admin folder
|_ /admin/cp.html: Possible admin folder
|_ /admin/index.jsp: Possible admin folder
|_ /admin/login.jsp: Possible admin folder
|_ /admin/admin.jsp: Possible admin folder
|_ /admin/home.jsp: Possible admin folder
|_ /admin/controlpanel.jsp: Possible admin folder
|_ /admin/admin-login.jsp: Possible admin folder
|_ /admin/cp.jsp: Possible admin folder
|_ /admin/account.jsp: Possible admin folder
|_ /admin/admin_login.jsp: Possible admin folder
|_ /admin/adminLogin.jsp: Possible admin folder
|_ /manager/html/upload: Apache Tomcat (401 Unauthorized)
|_ /manager/html: Apache Tomcat (401 Unauthorized)
|_ /admin/view/javascript/fckeditor/editor/filemanager/connectors/test.html: OpenCart/FCKeditor File upload
|_ /admin/includes/FCKeditor/editor/filemanager/upload/test.html: ASP Simple Blog / FCKeditor File Upload
|_ /admin/jscript/upload.html: Lizard Cart/Remote File upload
|_ /webdav/: Potentially interesting folder
MAC Address: 00:0C:29:FA:DD:2A (VMware)

Host script results:
|_ smb-vuln-regsvc-dos: ERROR: Script execution failed (use -d to debug)
|_ smb-vuln-ms10-061: false
|_ smb-vuln-ms10-054: false

Nmap done: 1 IP address (1 host up) scanned in 563.08 seconds

```

Figure 29: Nmap Vulnerability Scan Results (Part 7)

6. Findings Summary & Risk Matrix

Risk Level	Count	Services Affected	Priority
CRITICAL	4	FTP, SMB, IRC, Bindshell Backdoor	Immediate
HIGH	6	VNC, phpMyAdmin, MySQL	Urgent
MEDIUM	6	Telnet, R-Services, NFS, RMI, Tomcat, SSH	High

LOW	4+	Web apps, outdated libraries, BIND	Moderate
-----	----	------------------------------------	----------

7. Conclusion

The Week 1 reconnaissance phase successfully mapped the complete attack surface of the Metasploitable 2 target. Passive reconnaissance established the web technology stack, while active reconnaissance revealed 23 open ports hosting 23 services the majority running outdated, vulnerable, or misconfigured software.

Key highlights:

- vsftpd 2.3.4 backdoor (Port 21) CVE-2011-2523 direct exploitation vector
- Samba 3.0.20 remote code execution (Port 445) CVE-2007-2447
- UnrealIRCd 3.2.8.1 backdoor (Port 6667) root access
- VNC with no authentication (Port 5900) complete GUI desktop access
- Port 1524 root shell intentional Metasploitable backdoor
- MySQL remote root with no password (Port 3306)
- Apache 2.2.8 (Port 80) End-of-Life since 2010
- OpenSSH 4.7p1 (Port 22) outdated with multiple known CVEs
- phpMyAdmin exposed (Port 80) database access with default credentials

These findings form the exploitation target list for Week 2, where individual vulnerabilities will be exploited using the Metasploit Framework and manual techniques.

8. Tools & References

Tool	Purpose
Nmap 7.94	Port scanning, OS detection, service/version enumeration, vuln scripts
Netdiscover	ARP-based host discovery and MAC address identification
Whois	Domain registration and network block information
Dig / Host	DNS record enumeration (A, AAAA, MX, NS, CNAME, TXT)
Nikto 2.1.6	Web server vulnerability scanning and technology fingerprinting
Gobuster	Directory and file brute-forcing for web enumeration

WhatWeb	Web technology fingerprinting — CMS, frameworks, server info
Netcat (nc)	Manual service banner grabbing from open ports
Curl	HTTP requests — robots.txt, sitemap, directory enumeration
